



Chính sách Bảo vệ Dữ liệu

Viện Nghiên Cứu Xây Dựng & Đô Thị

1. Tuyên Bố và Mục Đích

1.1. Tuyên Bố Chính Sách Tại Viện Nghiên Cứu Xây Dựng & Đô Thị, chúng tôi xem việc bảo vệ dữ liệu cá nhân của nhân viên, khách hàng và đối tác là ưu tiên hàng đầu. Chúng tôi cam kết tuân thủ các quy định pháp luật liên quan đến bảo vệ dữ liệu cá nhân tại Việt Nam, đặc biệt là **Nghị định 13/2023/NĐ-CP** về bảo vệ dữ liệu cá nhân, cũng như các tiêu chuẩn bảo mật quốc tế.

1.2. Mục Đích của Tài Liệu Sổ tay này được lập ra nhằm mục đích:

- Thiết lập các nguyên tắc và quy định rõ ràng về việc thu thập, xử lý, lưu trữ và bảo vệ dữ liệu.
- Nâng cao nhận thức và trách nhiệm của toàn bộ nhân viên trong việc bảo vệ dữ liệu.
- Cung cấp một khuôn khổ để xử lý các yêu cầu liên quan đến quyền của chủ thể dữ liệu và các sự cố vi phạm an ninh dữ liệu.

2. Phạm Vi Áp Dụng và Định Nghĩa Thuật Ngữ

2.1. Phạm Vi Áp Dụng Chính sách này áp dụng cho tất cả nhân viên (chính thức, thử việc, thời vụ), các đối tác, nhà thầu và bên thứ ba có quyền truy cập vào dữ liệu của công ty.

2.2. Định Nghĩa Thuật Ngữ | Thuật Ngữ | Định Nghĩa | | :--- | :--- | | **Dữ liệu cá nhân** | Thông tin gắn liền với một cá nhân cụ thể hoặc giúp xác định một cá nhân, bao gồm họ tên, ngày sinh, địa chỉ, số điện thoại, v.v. | | **Xử lý dữ liệu** | Một hoặc nhiều hành động tác động tới dữ liệu cá nhân như thu thập, ghi, phân tích, lưu trữ, xóa, v.v. | | **Chủ thể dữ liệu** | Cá nhân mà dữ liệu cá nhân đó phản ánh. | | **Bên thứ ba** | Bất kỳ tổ chức hoặc cá nhân nào ngoài công ty được phép xử lý dữ liệu nhân danh công ty. |

3. Nguyên Tắc Cốt Lõi về Bảo Vệ Dữ Liệu

- **Tính hợp pháp, công bằng và minh bạch:** Dữ liệu phải được xử lý một cách hợp pháp, công bằng và minh bạch đối với chủ thể dữ liệu.
- **Giới hạn mục đích:** Dữ liệu chỉ được thu thập cho các mục đích cụ thể, rõ ràng và hợp pháp, và không được xử lý theo cách không phù hợp với các mục đích đó.
- **Tối thiểu hóa dữ liệu:** Chỉ thu thập dữ liệu cần thiết và phù hợp với mục đích đã được xác định.
- **Tính chính xác:** Đảm bảo dữ liệu là chính xác và được cập nhật.
- **Giới hạn lưu trữ:** Dữ liệu phải được lưu trữ trong khoảng thời gian cần thiết cho mục đích đã thu thập.
- **Tính toàn vẹn và bảo mật:** Áp dụng các biện pháp kỹ thuật và tổ chức phù hợp để đảm bảo an toàn cho dữ liệu, chống lại sự truy cập, xử lý, mất mát hoặc phá hủy trái phép.

4. Phân Loại Dữ Liệu và Quy Trình Xử Lý

4.1. Phân Loại Dữ Liệu Chúng tôi phân loại dữ liệu dựa trên mức độ nhạy cảm và tầm quan trọng:

- **Cấp 1 - Công khai:** Dữ liệu đã được công khai hoặc không nhạy cảm (ví dụ: thông tin công khai về sản phẩm, địa chỉ công ty).
- **Cấp 2 - Nội bộ:** Dữ liệu dành cho các hoạt động nội bộ của công ty (ví dụ: email nội bộ, danh bạ nhân viên, báo cáo tài chính nội bộ).
- **Cấp 3 - Bí mật:** Dữ liệu nhạy cảm, nếu bị tiết lộ có thể gây ra thiệt hại đáng kể (ví dụ: thông tin khách hàng, hợp đồng, hồ sơ nhân sự).
- **Cấp 4 - Tối mật:** Dữ liệu nhạy cảm nhất, việc tiết lộ có thể gây ra hậu quả nghiêm trọng hoặc vi phạm pháp luật (ví dụ: bí mật kinh doanh, mã nguồn sản phẩm cốt lõi).

4.2. Quy Trình Thu Thập và Xử Lý Dữ Liệu

- **Thu thập:** Dữ liệu cá nhân chỉ được thu thập khi có sự đồng ý rõ ràng của chủ thể dữ liệu (bằng văn bản, email, hoặc xác nhận điện tử).
- **Sử dụng:** Dữ liệu chỉ được sử dụng cho mục đích đã được thông báo và đồng ý ban đầu. Mọi thay đổi về mục đích sử dụng phải được sự đồng ý mới của chủ thể dữ liệu.

- **Lưu trữ:** Dữ liệu phải được lưu trữ trên các hệ thống bảo mật, được phân quyền truy cập nghiêm ngặt.
- **Chia sẻ:** Dữ liệu chỉ được chia sẻ với bên thứ ba khi có hợp đồng, thỏa thuận bảo mật và sự đồng ý của chủ thể dữ liệu (nếu cần).
- **Hủy bỏ:** Dữ liệu phải được xóa hoặc ẩn danh một cách an toàn khi không còn cần thiết cho mục đích đã thu thập.

5. Các Biện Pháp An Ninh Dữ Liệu

5.1. An ninh Kỹ thuật số

- **Bảo mật hệ thống:** Sử dụng tường lửa (firewall), phần mềm diệt virus và các giải pháp an ninh mạng để bảo vệ hệ thống khỏi các cuộc tấn công.
- **Kiểm soát truy cập:** Thiết lập các chính sách mật khẩu mạnh và phân quyền truy cập dựa trên nguyên tắc "cần biết" (need-to-know).
- **Mã hóa:** Mã hóa dữ liệu nhạy cảm trong quá trình lưu trữ và truyền tải.
- **Sao lưu định kỳ:** Sao lưu dữ liệu quan trọng định kỳ để có thể phục hồi trong trường hợp xảy ra sự cố.

5.2. An ninh Vật lý

- **Phòng máy chủ:** Hạn chế quyền truy cập vào phòng máy chủ bằng thẻ từ, khóa vân tay.
- **Tài liệu giấy:** Lưu trữ tài liệu chứa dữ liệu nhạy cảm trong tủ khóa.

5.3. Bảng phân quyền truy cập (ví dụ) | Dữ liệu | Phòng Ban được cấp quyền truy cập |
Mức độ truy cập | | :--- | :--- | :--- | | **Hồ sơ nhân sự** | Phòng Nhân sự | Toàn quyền (đọc, chỉnh sửa) | | Ban Giám đốc | Quyền xem | | **Thông tin khách hàng** | Phòng Kinh doanh, Chăm sóc khách hàng | Toàn quyền | | Phòng Marketing | Quyền xem (dữ liệu ẩn danh) | | **Báo cáo tài chính** | Phòng Kế toán | Toàn quyền | | Ban Giám đốc | Toàn quyền |

6. Quyền của Chủ Thể Dữ Liệu và Xử Lý Vi Phạm

6.1. Các Quyền của Chủ Thể Dữ Liệu Theo Nghị định 13/2023/NĐ-CP, chủ thể dữ liệu có các quyền sau:

- **Quyền được biết:** Được thông báo về việc xử lý dữ liệu của mình.
- **Quyền đồng ý:** Có quyền đồng ý hoặc không đồng ý cho việc xử lý dữ liệu.
- **Quyền truy cập:** Yêu cầu được xem và sao chép dữ liệu của mình.
- **Quyền chỉnh sửa:** Yêu cầu chỉnh sửa dữ liệu không chính xác.
- **Quyền xóa:** Yêu cầu xóa dữ liệu của mình khi không còn cần thiết.

6.2. Quy trình xử lý yêu cầu

- Mọi yêu cầu liên quan đến quyền của chủ thể dữ liệu phải được gửi đến Bộ phận IT hoặc Nhân sự qua email.
- Công ty sẽ xác minh danh tính của người yêu cầu và xử lý yêu cầu trong vòng 30 ngày làm việc.

6.3. Xử lý vi phạm an ninh dữ liệu

- **Phát hiện:** Khi phát hiện một sự cố, nhân viên phải báo cáo ngay cho người quản lý trực tiếp và Bộ phận IT.
- **Điều tra:** Bộ phận IT sẽ tiến hành điều tra để xác định nguyên nhân và phạm vi của sự cố.
- **Khắc phục:** Thực hiện các biện pháp khắc phục để ngăn chặn sự cố lặp lại.
- **Thông báo:** Thông báo cho chủ thể dữ liệu bị ảnh hưởng (nếu cần) và báo cáo cho cơ quan chức năng theo quy định của pháp luật.

7. Trách Nhiệm và Cam Kết

7.1. Trách nhiệm của các bộ phận

- **Ban Lãnh đạo:** Thiết lập chính sách, phân bổ nguồn lực và giám sát việc tuân thủ.
- **Bộ phận IT:** Chịu trách nhiệm chính về an ninh mạng, bảo trì hệ thống và các biện pháp bảo mật kỹ thuật.

- **Bộ phận Nhân sự:** Chịu trách nhiệm về bảo vệ dữ liệu của nhân viên và đào tạo nhận thức về chính sách này.
- **Tất cả nhân viên:** Có trách nhiệm tuân thủ chính sách, bảo vệ thông tin mà mình được giao phó và báo cáo mọi vi phạm.

7.2. Cam kết Tuân thủ Tôi đã đọc, hiểu và cam kết tuân thủ chính sách bảo vệ dữ liệu và quyền riêng tư của Công ty Cổ phần Phát triển Công nghệ XYZ. Tôi hiểu rằng việc không tuân thủ có thể dẫn đến hậu quả nghiêm trọng cho công ty và bản thân, bao gồm các hình thức kỷ luật theo quy định của công ty.

Họ và Tên: _____

Chức danh: _____

Ngày: _____

Chữ Ký: _____